



دانشگاه صنعتی شریف

دانشکده‌ی مهندسی کامپیوتر

دوره‌ی کارشناسی ارشد

زمان تحویل تمرین: ۲۴ خرداد ۱۴۰۵

تاریخ انتشار: ۱۰ خرداد ۱۴۰۵

مدرس: سولماز سلیمی

تمرین اول: درس امنیت سامانه‌های نهفته و اینترنت اشیا

موضوع تمرین

در این تمرین، یک سرویس ساده برای به‌روزرسانی ثابت‌افزار روی ESP32 در اختیار شماست. دستگاه از طریق Wi-Fi فایل manifest و یک فایل باینری آزمایشی را دریافت می‌کند و پیش از پذیرش بسته، چند فیلد اصلی manifest را بررسی می‌کند. هدف تمرین، بررسی عملی تفاوت میان «سالم بودن فایل» و «قابل اعتماد بودن بسته‌ی به‌روزرسانی» است. در پایان باید بتوانید توضیح دهید که چرا بررسی hash به‌تنهایی برای اعتماد به بسته کافی نیست و برای جلوگیری از بسته‌های جعلی یا بازگشت به نسخه‌های قدیمی‌تر چه سازوکارهایی لازم است.

در این تمرین ثابت‌افزار جدید روی پارتیشن‌های OTA نوشته نمی‌شود. تمرکز کار روی اعتبارسنجی manifest، بررسی بسته‌ی به‌روزرسانی، سیاست نسخه و مستندسازی نتیجه است.

فایل‌های داده‌شده

در کنار صورت تمرین، یک پروژه‌ی کامل ESP-IDF و چند ابزار کمکی در اختیار شما قرار می‌گیرد. ساختار کلی پروژه به شکل زیر است:

```
E2_firmware_update/  
  CMakeLists.txt  
  sdkconfig.defaults  
  main/  
    CMakeLists.txt  
    idf_component.yml  
    main.c  
  tools/  
    make_manifest.py
```

فایل `main.c` نسخه‌ی اولیه‌ی سرویس به‌روزرسانی را پیاده‌سازی کرده است. ابزار `make_manifest.py` هم برای ساخت بسته‌های آزمایشی و تولید manifest استفاده می‌شود.

پیش نیازها

برای انجام تمرین، این موارد لازم است:

- یک برد مبتنی بر ESP32، مانند ESP32-S3
- نصب ESP-IDF
- یک شبکه‌ی Wi-Fi مشترک که لپ‌تاپ و برد در آن به یکدیگر دسترسی داشته باشند
- Python 3
- یک سرور HTTP محلی برای میزبانی فایل‌های manifest و فایل‌های باینری آزمایشی

در بعضی شبکه‌های عمومی یا دانشگاهی، ارتباط مستقیم بین دستگاه‌ها محدود است. اگر برد به شبکه وصل می‌شود اما فایل‌های روی لپ‌تاپ را دانلود نمی‌کند، از hotspot موبایل یا یک روتر محلی استفاده کنید و لپ‌تاپ و برد را به همان شبکه وصل کنید.

تنظیم شبکه و کامپایل پروژه

پیش از کامپایل، در فایل `main/main.c` نام شبکه و گذرواژه را تنظیم کنید. اگر شبکه رمز ندارد، مقدار گذرواژه را رشته‌ی خالی بگذارید.

```
#define LAB_WIFI_SSID "YOUR_WIFI_NAME"
#define LAB_WIFI_PASS "YOUR_WIFI_PASSWORD"
```

برای شبکه‌ی بدون رمز:

```
#define LAB_WIFI_SSID "Sharif-WiFi"
#define LAB_WIFI_PASS ""
```

سپس پروژه را بسازید و روی برد فلش کنید:

```
idf.py set-target esp32s3
idf.py build
idf.py -p /dev/ttyACM0 flash monitor
```

اگر از برد دیگری استفاده می‌کنید، هدف ESP-IDF و پورت سریال را متناسب با همان برد تغییر دهید.

رابط سریال دستگاه

بعد از بوت، دستگاه از طریق سریال یک CLI ساده در اختیار شما می‌گذارد. دستورهای اصلی عبارت‌اند از:

```
help
version
update_apply <manifest_url>
reset_state CONFIRM
```

نمونه‌ی خروجی دستور `version`:

```
> version
device_model=ce-40876
current_version=1
update_state=ready
```

شناسه‌ی مدل دستگاه در این تمرین `ce-40876` است. بسته‌های به‌روزرسانی باید برای همین مدل ساخته شوند.

ساخت بسته‌ی به‌روزرسانی

در این تمرین، هر بسته‌ی به‌روزرسانی دو فایل دارد:

- فایل `manifest` با قالب JSON
- فایل باینری آزمایشی ثابت‌افزار

نمونه‌ی `manifest`:

```
{
  "device_model": "ce-40876",
  "version": 2,
  "size": 21,
  "sha256": "...",
  "firmware_url": "http://<laptop-ip>:8000/fw_v2.bin"
}
```

برای میزبانی فایل‌ها روی لپ‌تاپ، دستور زیر را در پوشه‌ی بسته‌ی به‌روزرسانی اجرا کنید:

```
python3 -m http.server 8000
```

برای پیدا کردن IP لپ‌تاپ در لینوکس، می‌توانید از دستورهای زیر استفاده کنید:

```
hostname -I
ip -4 addr
```

سپس روی دستگاه، URL فایل `manifest` را به دستور `update_apply` بدهید:

```
> update_apply http://192.168.1.10:8000/manifest.json
```

آنچه باید انجام دهید

مرحله‌ی ۱: اجرای به‌روزرسانی عادی

ابتدا یک بسته‌ی معتبر بسازید و نشان دهید که دستگاه آن را می‌پذیرد. در گزارش، این موارد را بیاورید:

- دستور ساخت بسته

- دستور اجرای HTTP server
- دستور `update_apply`
- خروجی `version` پیش و پس از به‌روزرسانی

مرحله ۲: تحلیل اعتماد به بسته‌ی به‌روزرسانی

بررسی کنید اگر مهاجم بتواند فایل باینری و `manifest` را با هم تغییر دهد، دستگاه همچنان بسته را می‌پذیرد یا نه. برای این بخش، یک بسته‌ی تغییر یافته بسازید و نتیجه‌ی اجرای آن را روی برد مستند کنید. در گزارش توضیح دهید که بررسی SHA-256 دقیقاً چه چیزی را تضمین می‌کند و چه چیزی را تضمین نمی‌کند.

مرحله ۳: بررسی بازگشت به نسخه‌ی قدیمی‌تر

بعد از اینکه دستگاه یک نسخه‌ی جدیدتر را پذیرفت، بسته‌ای با شماره نسخه‌ی پایین‌تر بسازید و بررسی کنید که دستگاه آن را می‌پذیرد یا رد می‌کند. نتیجه را با خروجی سریال مستند کنید.

مرحله ۴: اصلاح طراحی و پیاده‌سازی

در نسخه‌ی اصلاح‌شده، دست‌کم این موارد باید پیاده‌سازی شود:

- بررسی مدل دستگاه و رد کردن بسته‌هایی که برای `ce-40876` نیستند
- بررسی اندازه‌ی فایل باینری
- بررسی SHA-256 فایل باینری
- افزودن امضای دیجیتال برای `manifest`
- رد کردن `manifest` با امضای نامعتبر
- ذخیره‌ی آخرین نسخه‌ی معتبر در NVS
- رد کردن بسته‌هایی که نسخه‌ی آن‌ها از آخرین نسخه‌ی معتبر پایین‌تر است

امضای دیجیتال باید روی محتوای اصلی `manifest` انجام شود، نه فقط روی فایل باینری. به این ترتیب خود `manifest`، شامل نسخه، مدل دستگاه، اندازه، `hash` و آدرس فایل، قابل اعتماد می‌شود.

تست‌های پیشنهادی

در نسخه‌ی نهایی، حداقل این پنج حالت را تست کنید:

سناریو	رفتار مورد انتظار در نسخه‌ی امن
بسته‌ی معتبر و امضا شده با نسخه‌ی جدیدتر	پذیرفته شود
manifest با امضای نامعتبر	رد شود
بسته‌ی امضا شده با نسخه‌ی قدیمی‌تر	رد شود
manifest برای مدل دستگاه دیگر	رد شود
فایل باینری با hash نادرست	رد شود

تحويل دادنی ها

نکته ی مهم: همه ی تحويل دادنی ها باید در سامانه ی CW بارگذاری شوند. برای این تمرین، ارسال از طریق پیام رسان یا ایمیل پذیرفته نمی شود.

۱. کد کامل پروژه شامل پروژه ی ESP-IDF اصلاح شده و فایل های کمکی لازم برای ساخت بسته های به روزرسانی است.
۲. بسته های آزمایشی حداقل شامل یک بسته ی معتبر، یک بسته ی تغییر یافته، یک بسته با نسخه ی قدیمی تر، یک بسته با مدل دستگاه اشتباه و یک بسته با hash نادرست باشد.
۳. اسکرپت های کمکی اسکرپت ساخت manifest، محاسبه ی hash و تولید یا بررسی امضا را تحويل دهید.
۴. ویدئو یا اسکرین کست کوتاه یک ویدئوی حدود ۳ تا ۶ دقیقه ای که اجرای به روزرسانی عادی، یک نمونه رد شدن بسته و نسخه ی اصلاح شده را نشان دهد.
۵. گزارش کوتاه فایل `README.md` که معماری، نحوه ی اجرا، تهدیدهای بررسی شده، تست ها، خروجی ها و محدودیت های کار را توضیح دهد.

نمره دهی (۲۰ نمره)

نمره	مورد ارزیابی
۳	کامپایل، فلش و اجرای موفق سرویس به روزرسانی روی برد
۳	ساخت و اجرای بسته ی به روزرسانی عادی
۳	تحلیل و نمایش ضعف در اعتماد به بسته ی تغییر یافته
۳	بررسی و مستندسازی سناریوی بازگشت به نسخه ی قدیمی تر
۴	افزودن و پیاده سازی درست امضای manifest
۲	پیاده سازی سیاست نسخه و ذخیره ی آخرین نسخه در NVS
۲	گزارش، ویدئو، اسکرپت ها و تکرارپذیری

راهنمای کوتاه خطاهای رایج

- اگر دستگاه network=ready نشان نمی‌دهد، نام شبکه و رمز عبور را بررسی کنید.
- اگر دستگاه به Wi-Fi وصل است اما فایل را دانلود نمی‌کند، ممکن است شبکه ارتباط مستقیم بین لپ‌تاپ و برد را محدود کرده باشد.
- اگر از Sharif-WiFi استفاده می‌کنید و اتصال مستقیم کار نمی‌کند، از hotspot موبایل یا روتر محلی استفاده کنید.
- اگر URL روی لپ‌تاپ کار می‌کند اما روی برد کار نمی‌کند، مطمئن شوید IP داخل URL آدرس قابل دسترس لپ‌تاپ در همان شبکه است، نه localhost.
- اگر بعد از چند تست، نسخه‌ی ذخیره‌شده در NVS باعث رد شدن بسته‌ها می‌شود، از دستور `reset_state` CONFIRM استفاده کنید.

ایمیل دستیاران آموزشی

نام دستیار آموزشی	آدرس ایمیل
سپهر ابراهیمی	sepehr.ebrahimi@ce.sharif.edu
امین انصاری	mohammadamin.ansarijafari@sharif.edu
مهدی بحرینی	bahreiny@ce.sharif.edu